

WEEK 5 – SECURITY TESTING REPORT

Student Name: Nimra Sabir Khan

Student ID: DHC-6738

Application: DemoQA Web Application

Project Information:

- **Project Name:** DemoQA Security Testing
- **Testing Tool:** OWASP ZAP Community Edition
- **Application Under Test:** <https://demoqa.com>
- **Testing Type:** Manual and Automated Security Testing

2. Objective

The objective of this testing was to perform basic security testing on the DemoQA web application using OWASP ZAP and manual testing techniques. The purpose was to identify possible vulnerabilities related to input validation, authentication, and common OWASP Top 10 security risks.

3. Test Environment

- Operating System: Windows
- Browser: Firefox
- Security Tool: OWASP ZAP
- Application: DemoQA
- Internet Connection: Local Network

4. OWASP Top 10 Concepts Studied

- Cross Site Scripting (XSS)
- SQL Injection
- Broken Authentication
- Sensitive Data Exposure
- Security Misconfiguration

5. Setup & Configuration

Initially, OWASP ZAP proxy interception was enabled to capture browser traffic.

◆ Issue Faced:

Browser displayed:

“Your connection is not private”

◆ **Cause:**

HTTPS interception required proper SSL certificate trust configuration in the browser.

◆ **Resolution:**

To continue testing, manual explore mode and automated scanning were used successfully for traffic analysis.

6. Testing Approach

Security testing was performed using both automated and manual techniques.

6.1 Automated Security Scan

- DemoQA URL added into OWASP ZAP
- Automated scan/attack started
- ZAP crawled the full application
- Endpoints and assets were analyzed
- Vulnerability alerts generated

◆ **Coverage:**

- Homepage
- Forms section
- Practice form endpoint
- Static assets
- Third-party scripts

◆ **Result:**

- Informational alerts generated
- Missing security headers detected
- No critical or high-risk vulnerabilities found

6.2 Manual Security Testing (Practice Form Page)

Manual testing was performed specifically on the **Automation Practice Form page**.

Tests Performed:

- Input validation testing
- XSS payload testing
- Login/authentication behavior observation
- Email validation testing
- Session/logout behavior observation

❖ **Observations (Manual Testing)**

➤ **Input Validation Testing**

Different invalid inputs and special characters were tested.

- Invalid formats were rejected
- Proper validation messages displayed
- Application handled invalid inputs safely

➤ **XSS Testing**

Payload used:

```
<script>alert(1)</script>
```

- Payload was not executed
- Treated as plain text
- No script execution observed

➤ **Authentication Testing**

(Book Store login behavior tested with invalid credentials)

- Invalid login attempts were rejected
- No authentication bypass observed
- Demo system behaves as validation demo environment

➤ **Email Validation Testing**

- Invalid email formats were rejected
- Client-side validation was properly enforced

❖ **Manual Testing Key Observation**

- Form UI showed submission success behavior
- However, no backend POST request containing user input was captured in proxy
- Indicates client-side form handling behavior

7. Proxy Traffic Observations

- Only GET requests observed for page loading
- No form submission payload detected
- Multiple third-party analytics and tracking requests captured
- Application heavily uses client-side scripts

8. Security Findings

VULN-01: Missing Security Headers

- **Severity:** Medium
- **Description:** Some recommended HTTP security headers were not present in the application responses.
- **Evidence:** OWASP ZAP automated scan results
- **Suggested Fix:** Implement security headers such as Content-Security-Policy and X-Frame-Options.

VULN-02: Informational Security Alerts

- **Severity:** Low
- **Description:** OWASP ZAP detected informational-level security warnings during automated scanning.
- **Evidence:** ZAP vulnerability/alerts list
- **Suggested Fix:** Review and improve overall server security configuration.

VULN-03: Input Validation Observation

- **Severity:** Low
- **Description:** Input fields were tested using special characters and invalid values during manual testing.
- **Evidence:** Manual testing observations and screenshots
- **Suggested Fix:** Continue improving input sanitization and validation mechanisms.

9. Overall Observations

- OWASP ZAP successfully captured application traffic
- Manual testing confirmed input validation behavior
- Automated scan identified informational-level issues
- XSS payload was not executed

- No authentication bypass detected
- No critical or high severity vulnerabilities found

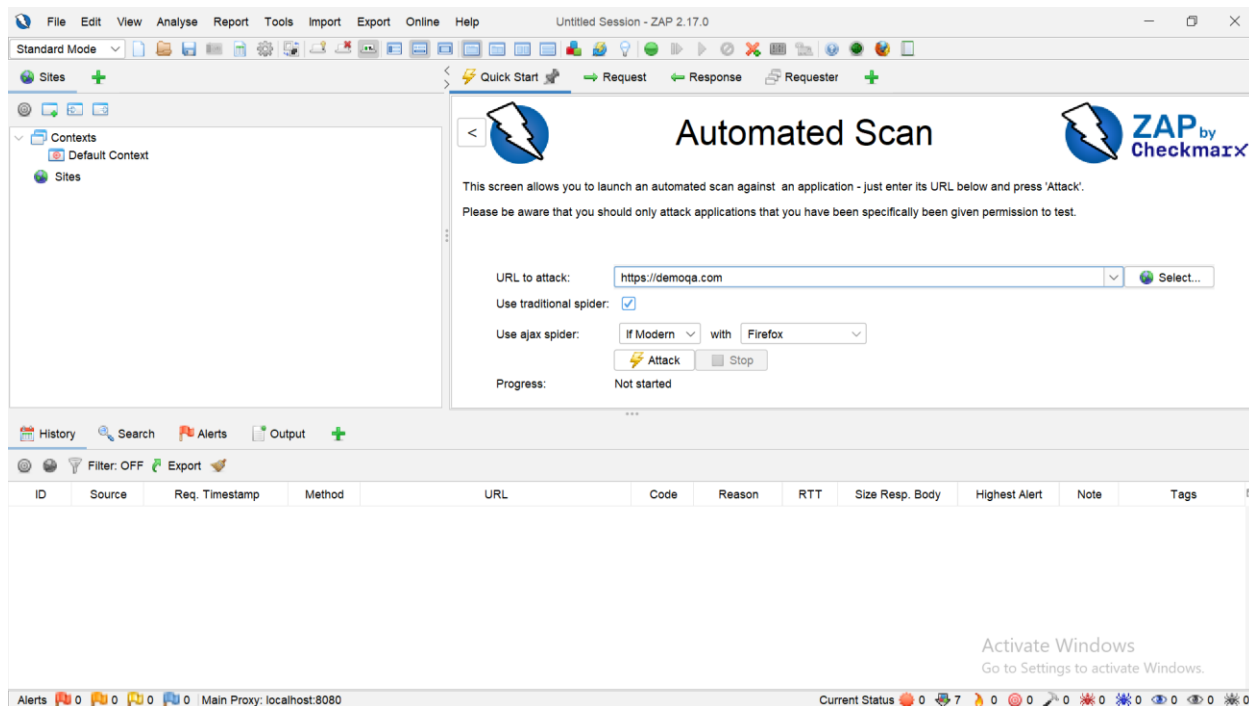
10. Conclusion

The DemoQA application demonstrated stable behavior during basic security testing. Both manual and automated testing techniques were successfully applied. No critical vulnerabilities were identified. Minor improvements in security headers and server configuration can enhance overall security posture.

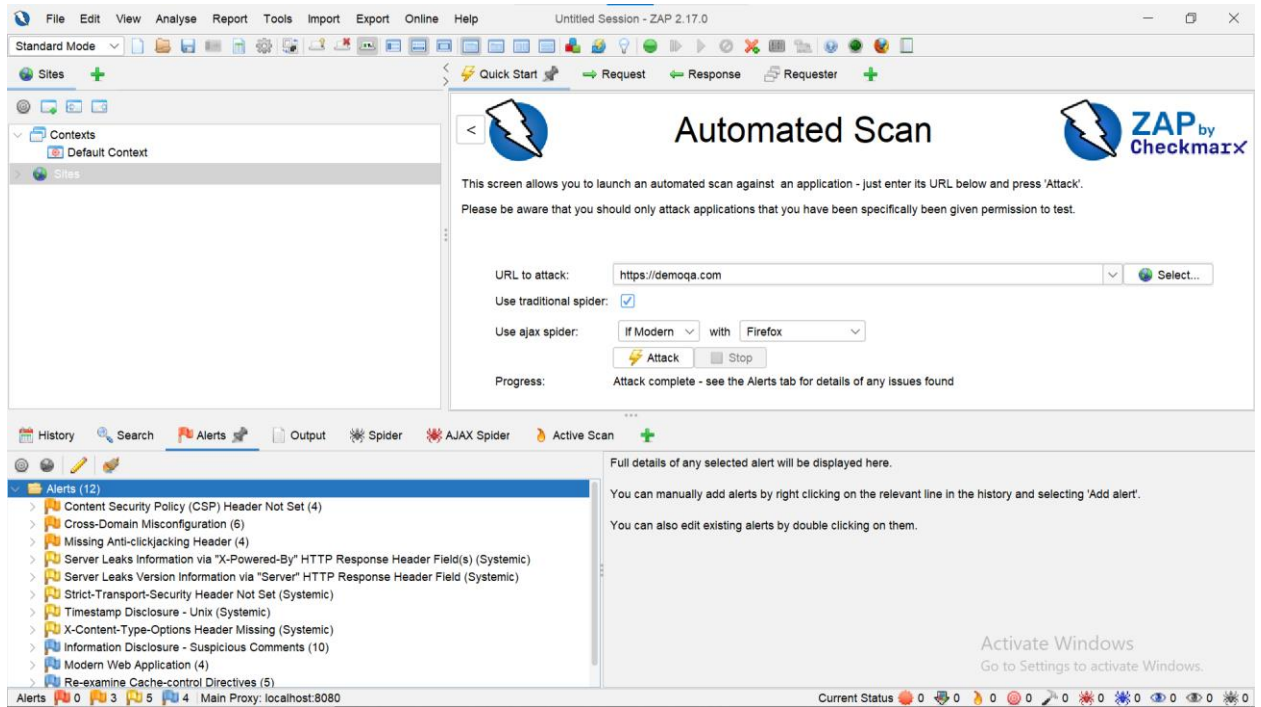
10. Attachments

The following screenshots and evidence are attached with this report:

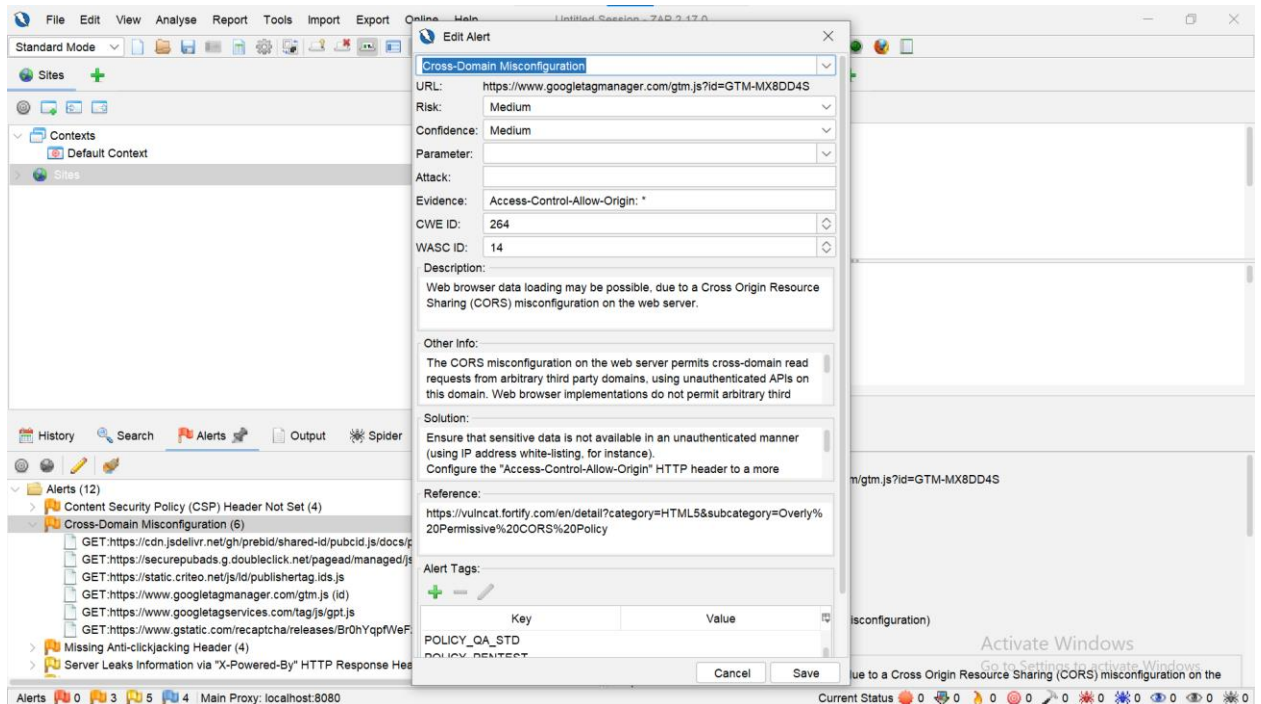
- **OWASP ZAP Automated Scan Screenshots**

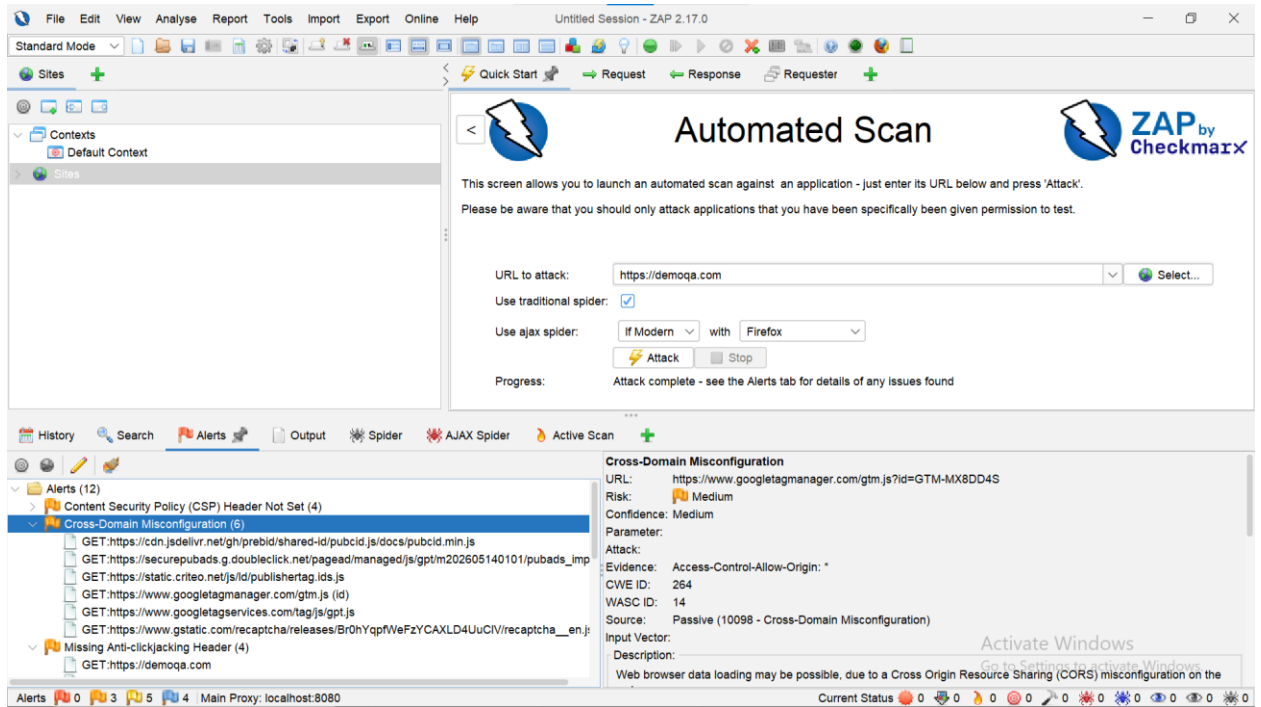


- **Vulnerability Alerts Screenshot**

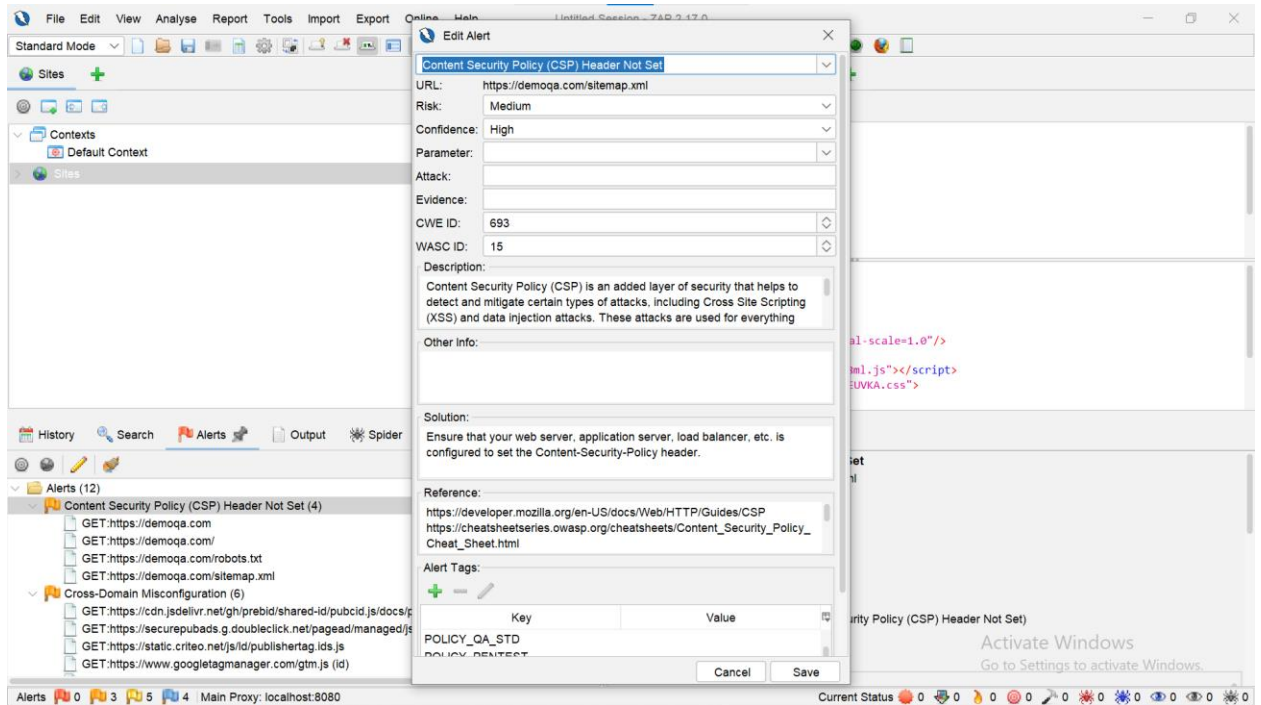


- Cross domain alert

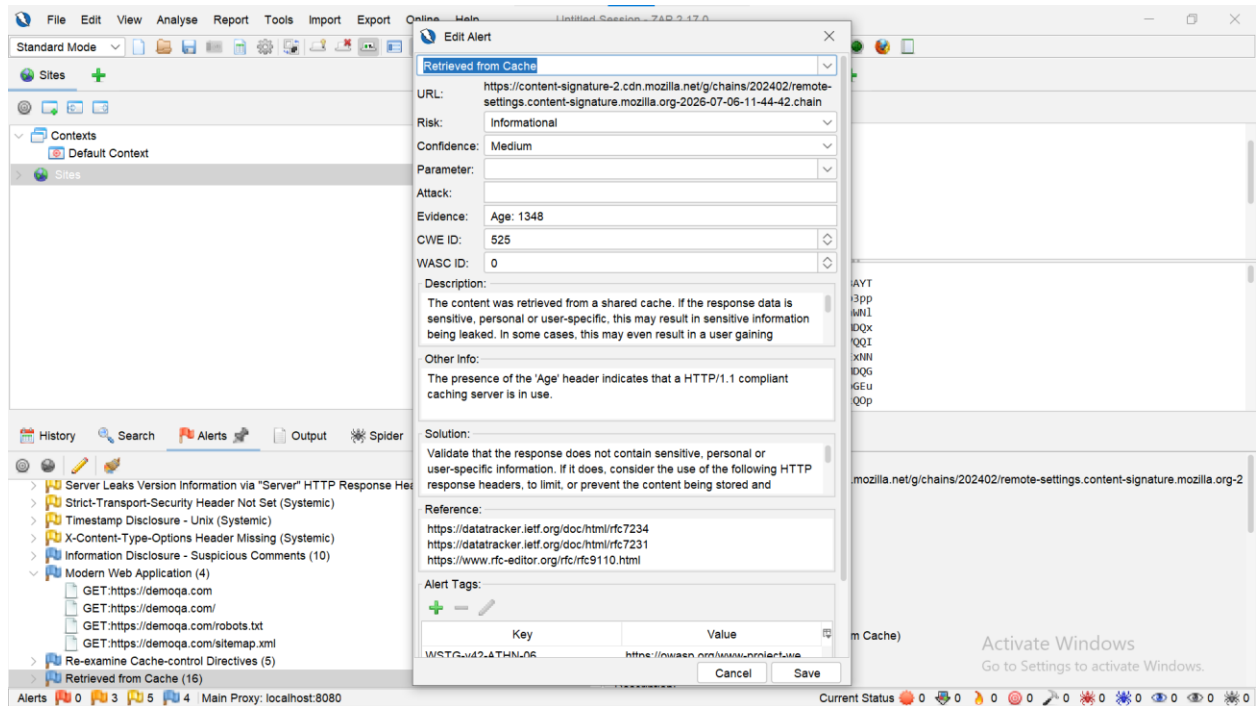




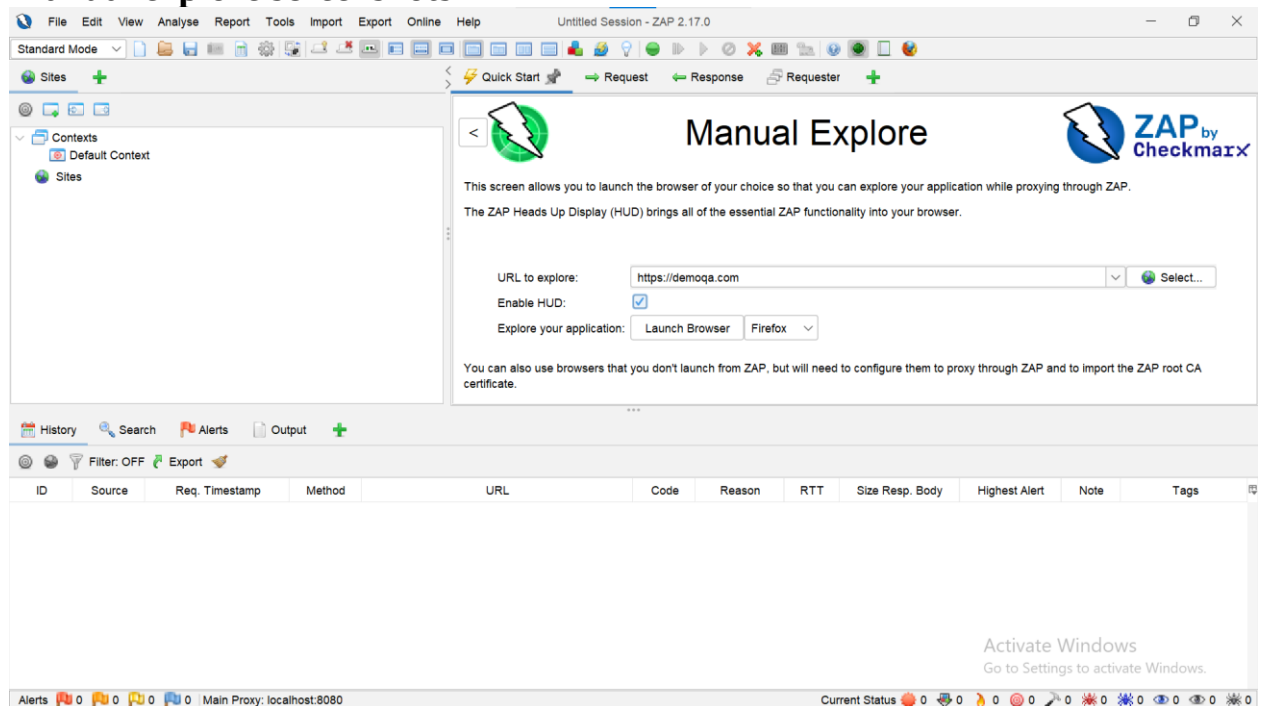
- Header not set alert



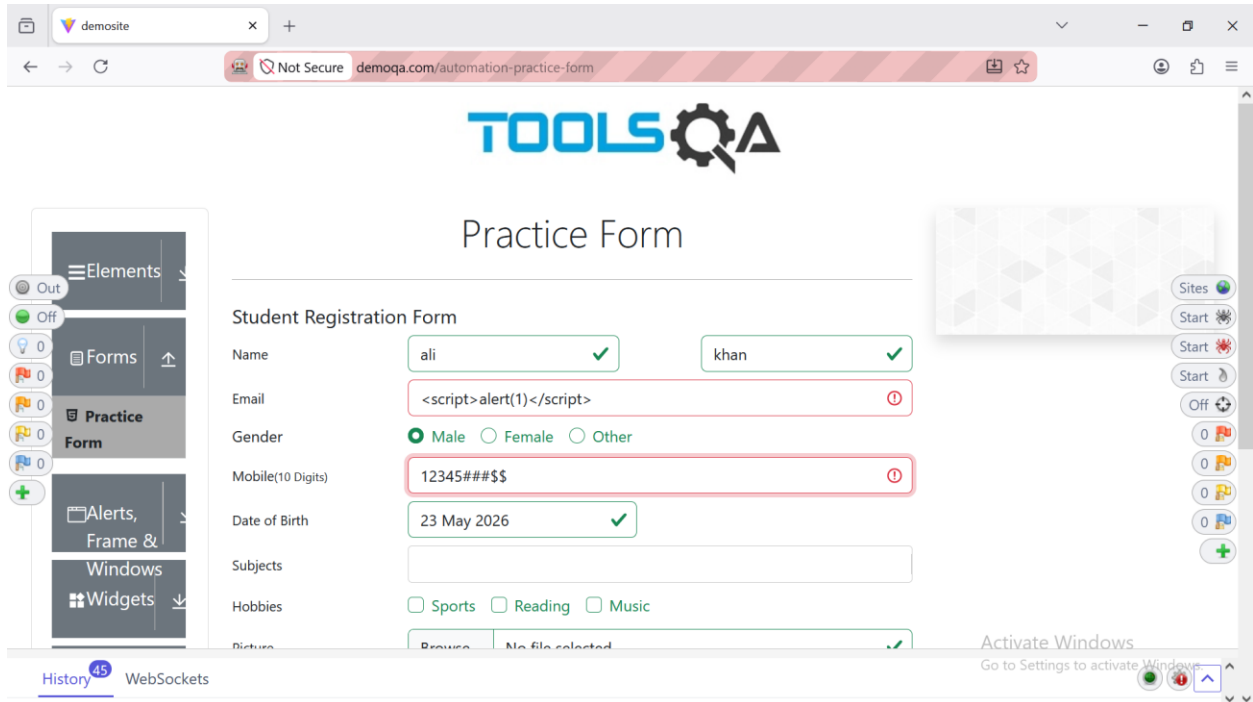
- Retrieved from cache alert



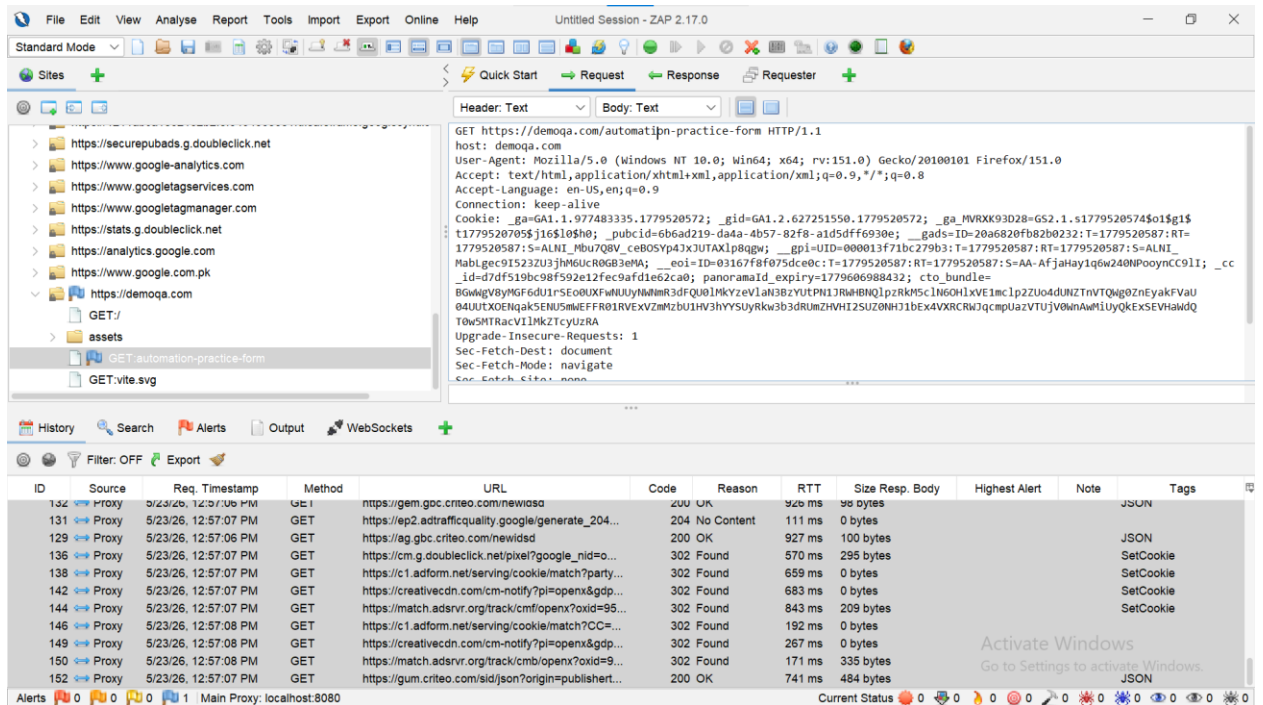
❖ Manual explore screenshots



- Client-side input validation detected on form fields



- HTTP request intercepted and analyzed using OWASP ZAP



- Passive scan results showing informational alerts

The screenshot shows the ZAP 2.17.0 interface. The left pane displays a site map with the following structure:

- https://securepubads.g.doubleclick.net
- https://www.google-analytics.com
- https://www.googleadservices.com
- https://www.googletagmanager.com
- https://stats.g.doubleclick.net
- https://analytics.google.com
- https://www.google.com.pk
- https://demoqa.com
 - assets
 - GET:/
 - GET:automation-practice-form
 - GET:vite.svg

The right pane shows the details of a selected alert:

Information Disclosure - Information in Browser localStorage

URL: https://demoqa.com/automation-practice-form

Risk: Informational

Confidence: High

Parameter: _pubcid

Attack:

Evidence:

CWE ID: 359

WASC ID: 13

Source: Passive (120000)

Alert Reference: 120000-1

Input Vector:

Description: Information was stored in browser localStorage

Alerts: 0 0 0 0 1 Main Proxy: localhost:8080

- Proxy captured HTTP requests for DemoQA Practice Form

The screenshot shows the ZAP 2.17.0 interface. The left pane displays the same site map as the previous screenshot.

The right pane shows the "Manual Explore" screen with the following text:

Manual Explore

This screen allows you to launch the browser of your choice so that you can explore your application while proxying through ZAP.

The ZAP Heads Up Display (HUD) brings all of the essential ZAP functionality into your browser.

URL to explore: https://demoqa.com

Enable HUD: ☐

Explore your application: Launch Browser Firefox

You can also use browsers that you don't launch from ZAP, but will need to configure them to proxy through ZAP and to import the ZAP root CA certificate.

The bottom pane shows a list of captured HTTP requests:

ID	Source	Req. Timestamp	Method	URL	Code	Reason	RTT	Size	Resp. Body	Highest Alert	Note	Tags
132	Proxy	5/23/26, 12:57:06 PM	GET	https://gem.gocriteo.com/newiso	200	OK	111 ms	0 bytes				JSON
131	Proxy	5/23/26, 12:57:06 PM	GET	https://ep2.adtrafficquality.google/generate_204...	204	No Content	111 ms	0 bytes				
129	Proxy	5/23/26, 12:57:06 PM	GET	https://ag.gbcriteo.com/newisd	200	OK	927 ms	100 bytes				JSON
136	Proxy	5/23/26, 12:57:07 PM	GET	https://cm.g.doubleclick.net/pixel?google_nid=o...	302	Found	570 ms	295 bytes				SetCookie
138	Proxy	5/23/26, 12:57:07 PM	GET	https://ic1.adform.net/serving/cookie/match?party...	302	Found	659 ms	0 bytes				SetCookie
142	Proxy	5/23/26, 12:57:07 PM	GET	https://creativecdn.com/cm-notify?pi=openx&gdp...	302	Found	683 ms	0 bytes				SetCookie
144	Proxy	5/23/26, 12:57:07 PM	GET	https://match.adsvr.org/track/cmf/openx?oxid=95...	302	Found	843 ms	209 bytes				SetCookie
146	Proxy	5/23/26, 12:57:08 PM	GET	https://ic1.adform.net/serving/cookie/match?CC=...	302	Found	192 ms	0 bytes				
149	Proxy	5/23/26, 12:57:08 PM	GET	https://creativecdn.com/cm-notify?pi=openx&gdp...	302	Found	267 ms	0 bytes				
150	Proxy	5/23/26, 12:57:08 PM	GET	https://match.adsvr.org/track/cmf/openx?oxid=9...	302	Found	171 ms	335 bytes				
152	Proxy	5/23/26, 12:57:07 PM	GET	https://gum.criteo.com/id/json?origin=publishert...	200	OK	741 ms	484 bytes				JSON

Alerts: 0 0 0 0 1 Main Proxy: localhost:8080